

OCTOBRE 2026 • MOIS EUROPÉEN DE LA CYBERSÉCURITÉ

Phishing : ne mordez pas à l'hameçon

Sensibilisation et plan d'action pour l'entreprise

Tafré Mefré
Service informatique



L'essentiel en une minute



LA MENACE

43 %

des incidents identifiés par les PME victimes viennent du phishing (24 % un an plus tôt).



LE PARADOXE

58 %

des PME se jugent bien protégées... mais 80 % ne se sentent pas prêtes face à une attaque.



L'ENJEU

+93 %

de demandes d'assistance pour faux ordres de virement en un an.



LA RÉPONSE

3

décisions simples et peu coûteuses : MFA, double validation des virements, culture du signalement.

Message clé : le phishing se combat d'abord par des réflexes et des procédures, pas seulement par des outils.

Au programme

01

La menace en chiffres

Pourquoi les PME sont devenues la cible privilégiée

6 min

02

Reconnaître une attaque

Les indices, les nouvelles ruses de l'IA, le quiz

10 min

03

Les bons réflexes

Avant, pendant et après un clic

7 min

04

Plan d'action

Ce que l'entreprise met en place

7 min



Format

- 30 minutes + questions
- Un quiz pour s'entraîner
- Une affiche A4 à garder
- Une version Direction de 20 minutes

01

La menace en chiffres

Pourquoi les PME sont devenues la cible privilégiée



Les PME, une cible de choix



44 %

des dirigeants de TPE-PME s'estiment
fortement exposés aux menaces
numériques

38 % en 2024



16 %

des PME ont subi au moins un
incident cyber au cours des 12
derniers mois

Soit environ 1 sur 6



3 sur 4

consacrent moins de 2 000 € par an à
leur cybersécurité

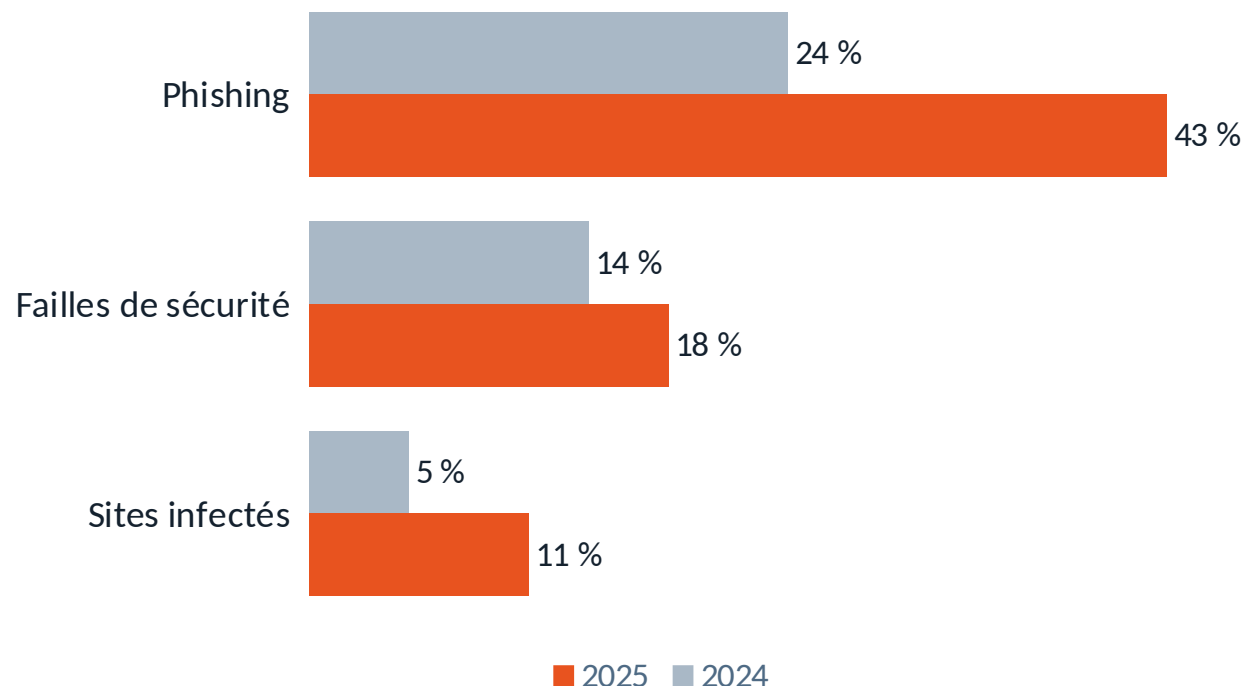
Peu de moyens, peu de procédures

« Trop petits pour intéresser les pirates » : c'est précisément ce qui fait des PME des cibles faciles.

Source : Cybermalveillance.gouv.fr / OpinionWay, baromètre national de la maturité cyber des TPE-PME, 2025 (588 entreprises de moins de 250 salariés)

Le phishing, 1re cause d'incident

Causes identifiées par les PME victimes d'un incident



43 %

des incidents identifiés par les PME victimes sont liés au phishing

Contre 24 % un an plus tôt : la part a presque doublé.



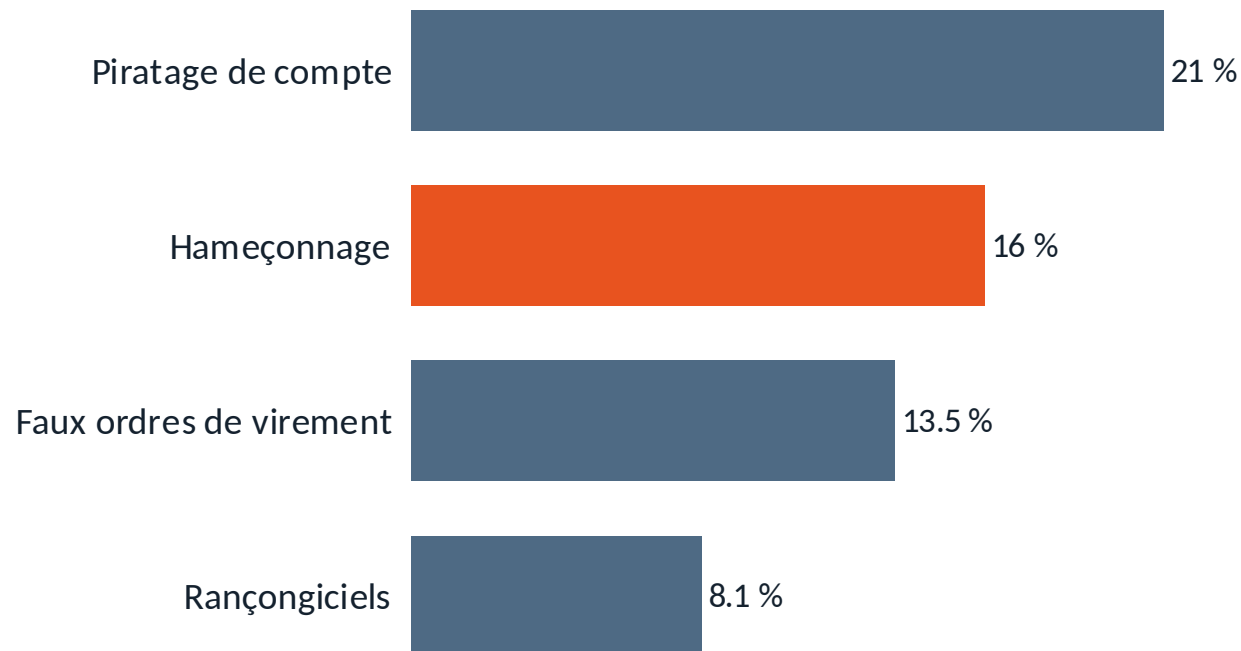
+70 %

de demandes d'assistance pour hameçonnage en 2025, tous publics confondus

Sources : Cybermalveillance.gouv.fr / OpinionWay, baromètre TPE-PME 2025 (plusieurs causes possibles) ; Cybermalveillance.gouv.fr, rapport d'activité 2025

Ce qui frappe les entreprises

Part des demandes d'assistance des entreprises et associations, 2025



ÉVOLUTION 2024 → 2025

Piratage de compte **+52 %**

Hameçonnage **+29 %**

Faux ordres de virement +93 %

À retenir

Le phishing est la porte d'entrée : un identifiant volé mène au piratage de compte, au faux virement ou au rançongiciel. Et +73 % d'entreprises ont demandé de l'aide en un an.

Source : [Cybermalveillance.gouv.fr](https://cybermalveillance.gouv.fr), rapport d'activité et état de la menace 2025 (publié en mars 2026)

Se sentir protégé n'est pas être protégé



58 %

des PME se jugent bien ou très bien protégées

39 % en 2024 : +19 points en un an

MAIS



80 %

ne se sentent pas prêtes face à une attaque

49 % se disent non préparées, 31 % ne savent pas

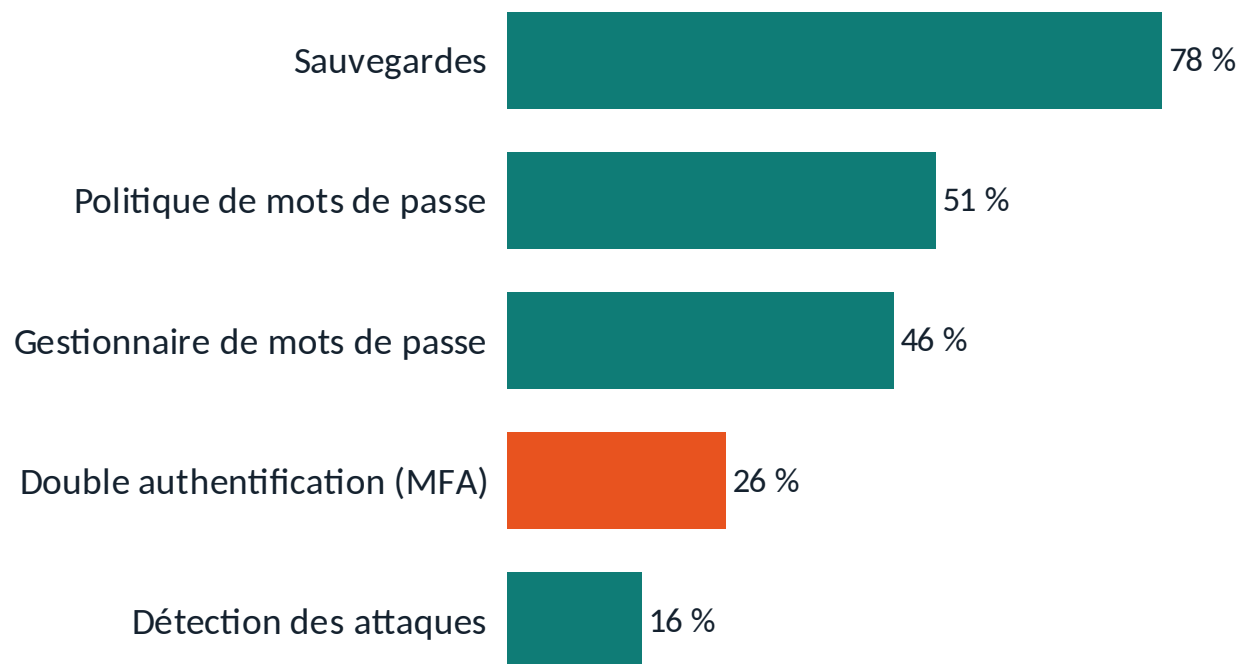


6 sur 10 ne sauraient pas évaluer les conséquences d'une cyberattaque sur leur activité.

Source : Cybermalveillance.gouv.fr / OpinionWay, baromètre national de la maturité cyber des TPE-PME, 2025

Les protections de base restent minoritaires

Part des PME équipées, 2025



26 %

seulement des PME utilisent la double authentification (MFA)



–99 %

de risque de piratage d'un compte protégé par MFA (Microsoft)

19 % du budget informatique va désormais à la cybersécurité (13 % en 2024) : la tendance est bonne.

Sources : Cybermalveillance.gouv.fr / OpinionWay, baromètre TPE-PME 2025 ; Microsoft Research, « How effective is multifactor authentication at deterring cyberattacks? », 2023

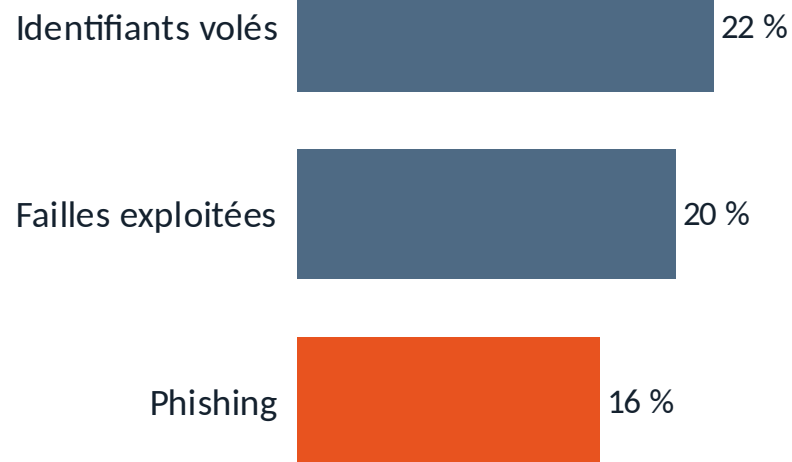
Le facteur humain, porte d'entrée



60 %

des violations de données
impliquent un facteur humain : clic,
erreur ou manipulation

Comment les attaquants entrent



×4

de signalements chez les
collaborateurs formés récemment
(21 % contre 5 %)

Objectif réaliste : pas zéro clic, mais une alerte rapide. Une équipe qui signale vite est une équipe qui protège.

Source : Verizon, Data Breach Investigations Report (DBIR) 2025

Ce qu'un clic peut coûter



Perte financière

Un virement frauduleux est rarement récupéré s'il n'est pas signalé dans l'heure.



Arrêt d'activité

Postes chiffrés, messagerie bloquée : plus de commandes ni de factures.



Fuite de données

Clients, salariés, fournisseurs : des données que nous devons protéger.



Confiance

Nos clients et partenaires peuvent être piégés à leur tour en notre nom.



Deux horloges de 72 h



Plainte sous 72 h

Condition légale pour être indemnisé par l'assurance cyber (Code des assurances, art. L12-10-1).



CNIL sous 72 h

Notification obligatoire en cas de violation de données personnelles à risque (RGPD, art. 33).

Un clic caché trois jours peut coûter l'indemnisation.

Sources : loi n° 2023-22 du 24 janvier 2023 (LOPMI), art. 5 ; règlement (UE) 2016/679 (RGPD), art. 33

02

Reconnaître une attaque

Les indices qui ne trompent pas, et ceux qui ne suffisent plus



Anatomie d'un e-mail piégé



- 1 Expéditeur trompeur**
« micr0soft » avec un zéro : le domaine imite le vrai.
- 2 Urgence et menace**
On vous pousse à agir avant de réfléchir.
- 3 Pièce jointe inattendue**
Un .zip ou une facture que vous n'attendiez pas.
- 4 Formule générique**
« Cher utilisateur » : il ne vous connaît pas. Avec l'IA, les fautes se font rares.
- 5 Lien déguisé**
Au survol, le bouton révèle une adresse raccourcie ou étrangère.

Le phishing a plusieurs visages



E-mail

Faux mails de banques, de fournisseurs, d'administrations ou de services en ligne.



SMS (smishing)

Faux colis, amendes, impôts ou banque, avec un lien piégé.



Téléphone (vishing)

Faux conseiller bancaire ou faux support technique qui demande un code.



Fraude au président

Un faux dirigeant exige un virement urgent et confidentiel.

La plus coûteuse



QR code (quishing)

Un QR code piégé, collé ou envoyé, mène vers un faux site de connexion.



Messageries pro

Faux messages sur Teams, LinkedIn ou WhatsApp, parfois depuis un compte piraté.

L'IA rend les pièges plus crédibles



Des messages sans fautes

Rédigés par IA et personnalisés grâce aux données volées lors de fuites : votre nom, votre poste, vos fournisseurs.



Des voix et des visages clonés

En 2024, un salarié d'Arup a viré 25 M\$ après une visioconférence où son directeur financier et ses collègues étaient des deepfakes.



Le MFA contourné

Des kits de phishing interceptent le code reçu par SMS, ou harcèlent de notifications jusqu'à ce qu'on accepte.

La nouvelle règle :
on ne juge plus un message à sa forme, mais à ce qu'il demande.

Argent

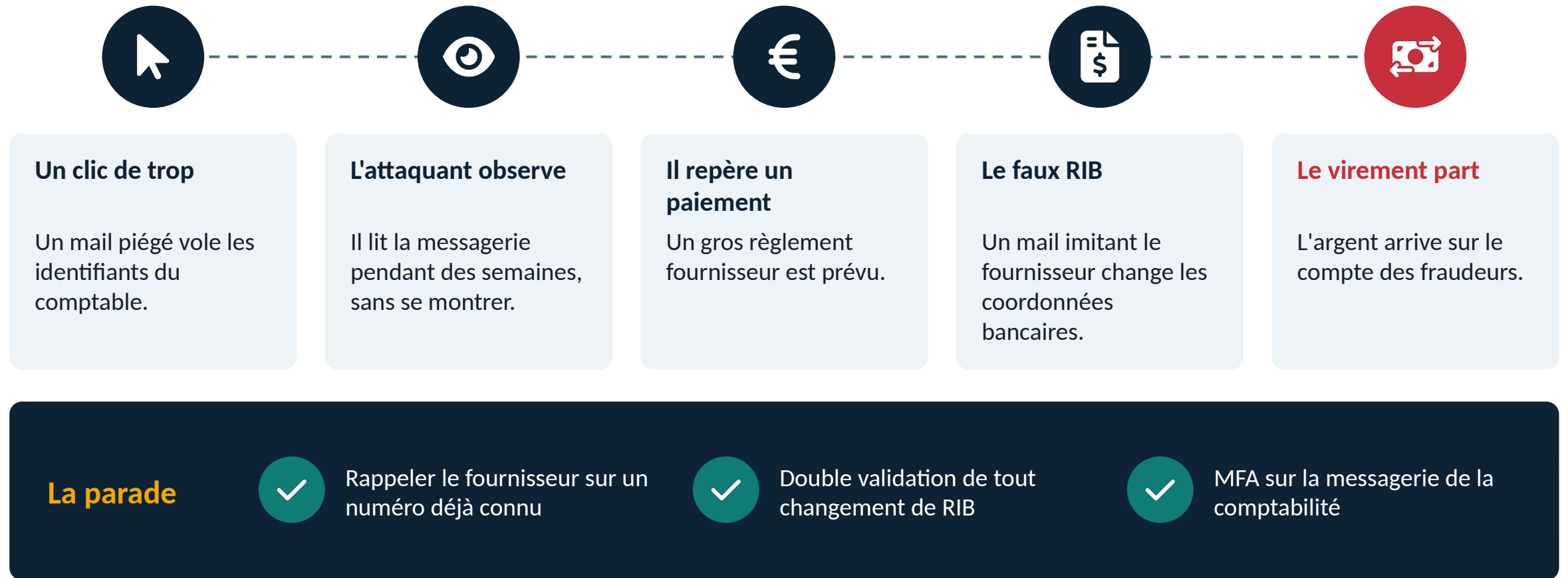
Identifiants

Urgence

Secret

Sources : [Cybermalveillance.gouv.fr](https://cybermalveillance.gouv.fr), rapport d'activité 2025 (personnalisation par les données fuitées) ; affaire Arup, Hong Kong, janvier 2024, confirmée par l'entreprise en mai 2024

Scénario : la fraude au faux RIB



Scénario illustratif, inspiré de cas fréquents en PME

À vous de jouer : piégé ou légitime ?



E-mail 1

De : impots-gouv@secure-remboursement.info

Objet : Remboursement de 312,40 € en attente

« Cliquez sous 24 h pour le recevoir sur votre compte. »

Piégé ou légitime ?



E-mail 2

De : Marie Durand
<marie.durand@votre-entreprise.fr>

Objet : Réunion jeudi 14 h : ordre du jour

« L'ordre du jour est en pièce jointe (PDF). »

Piégé ou légitime ?



E-mail 3

De : Direction
<dirigeant.pro@outlook.com>

Objet : Urgent et confidentiel

« Virement de 18 500 € à faire aujourd'hui. Je suis en rendez-vous, ne m'appellez pas. »

Piégé ou légitime ?

Indices à chercher : le domaine de l'expéditeur, l'urgence, le contexte attendu ou non.

Les réponses

E-mail 1

PIÉGÉ

- Domaine non officiel : le vrai est impots.gouv.fr
- Promesse d'argent
- Délai de 24 h pour vous presser

Le bon réflexe : Aller soi-même sur impots.gouv.fr, sans passer par le lien.

E-mail 2

LÉGITIME, a priori

- Collègue connu, domaine de l'entreprise
- Réunion attendue, pièce jointe cohérente
- Un doute ? Un appel suffit

Le bon réflexe : Si le PDF demande de se reconnecter : stop, on signale.

E-mail 3

PIÉGÉ

- Adresse externe (outlook.com)
- Urgence + confidentialité
- « Ne m'appellez pas » : on empêche la vérification

Le bon réflexe : Rappeler le dirigeant sur son numéro habituel.

Point commun des pièges : ils vous empêchent de vérifier. La parade : un autre canal.

03

Les bons réflexes

Avant, pendant et après un clic



6 réflexes à adopter dès aujourd'hui



Je lis l'adresse complète

Pas seulement le nom affiché : le domaine après le @ doit être exact.



Je survole avant de cliquer

L'adresse réelle du lien s'affiche au survol (appui long sur mobile).



Je me méfie de l'urgence

Menace, délai, confidentialité : autant de signaux d'alerte.



Mot de passe : jamais par message

Aucun service sérieux ne le demande par e-mail, SMS ou téléphone.



Je vérifie par un autre canal

Virement ou nouveau RIB : je rappelle sur un numéro déjà connu.



Je signale, même dans le doute

Je préviens le service informatique : mieux vaut une alerte de trop.

Ces six réflexes existent en affiche A4, à imprimer et à afficher près des postes.

J'ai cliqué : que faire ?



Chaque minute compte

Agissez dans l'ordre et sans honte : le pire est de se taire.

Plainte sous 72 h pour préserver l'indemnisation de l'assurance.

1

Ne répondez pas, ne cliquez plus

Gardez le message : il servira de preuve.

2

Isolez l'appareil

Coupez le Wi-Fi ou débranchez le câble réseau, sans éteindre l'ordinateur.

3

Alertez immédiatement

Le service informatique déclenche la réponse et prévient la direction.

4

Changez vos mots de passe

Depuis un autre appareil ; prévenez la banque si des coordonnées ont été saisies.

5

Signalez et faites-vous aider

17Cyber.gouv.fr ; plainte sous 72 h en cas de préjudice.

Qui contacter ?



EN INTERNE, D'ABORD

Service informatique

Tafré Mefré

*Mieux vaut une alerte de trop
qu'un silence.*



17Cyber.gouv.fr

Diagnostic et assistance 24 h/24,
avec la police et la gendarmerie



Votre banque

Virement frauduleux : appeler
tout de suite pour tenter un
rappel des fonds



signal-spam.fr

Signaler un e-mail frauduleux



33700

Transférer gratuitement un SMS
frauduleux



Exercice de quishing

Avant d'ouvrir, vérifiez
l'adresse affichée : elle doit
être 17cyber.gouv.fr.

04

Plan d'action

Ce que l'entreprise met en place, et les décisions attendues



La direction, premier rempart



Pourquoi la direction ?

Dirigeants et comptabilité sont les cibles n°1 de la fraude au président : l'attaquant exploite l'autorité, l'urgence et la confidentialité.

Un collaborateur n'ose pas vérifier un ordre du patron... sauf si le patron l'y autorise.

1

Annoncer la règle

« Je ne demanderai jamais de virement urgent et confidentiel par e-mail, SMS ou téléphone. »

2

Accepter d'être vérifié

Un collaborateur qui rappelle pour confirmer applique la procédure : il faut le remercier.

3

Montrer l'exemple

MFA, procédure de virement, formation : les mêmes règles pour la direction.

4

Protéger qui signale

Aucune sanction après un clic signalé : la honte fait perdre des heures précieuses.

Plan d'action en trois temps

Sous 30 jours

Les bases

- MFA sur la messagerie et les comptes critiques, direction comprise
- Double validation des virements et des changements de RIB
- Un référent et une adresse de signalement connus de tous

→ *Bloque le scénario du faux RIB*

Sous 90 jours

Les protections

- Filtrage anti-phishing renforcé sur la messagerie
- SPF, DKIM et DMARC : empêcher l'usurpation de notre domaine
- Sauvegardes hors ligne, restauration testée

→ *Domaine protégé de l'usurpation*

Sous 12 mois

La culture

- Simulations de phishing trimestrielles, sans sanction
- Sensibilisation annuelle de tous (SensCyber, gratuit)
- Clés de sécurité ou passkeys pour les comptes sensibles
- Exercice de crise et plan de réponse à jour

→ *Le signalement devient un réflexe*

Les mesures clés coûtent peu

MESURE	COÛT	MISE EN PLACE	EFFET SUR LE RISQUE
 Double validation des virements et des RIB	Nul : une procédure	1 semaine	● ● ●
 MFA sur la messagerie et les comptes clés	Souvent inclus	2 à 4 semaines	● ● ●
 SPF, DKIM, DMARC sur notre domaine	Nul à faible	1 mois	● ● ○
 Sensibilisation annuelle (SensCyber)	Gratuit	Immédiat	● ● ○
 Simulations de phishing	Faible	3 mois	● ● ○
 Sauvegardes hors ligne testées	Modéré	3 mois	● ● ●

Estimations indicatives, à affiner selon nos outils actuels et nos prestataires. « Souvent inclus » : la plupart des suites bureautiques en ligne intègrent le MFA sans surcoût.

Mesurer pour progresser



Taux de signalement
en simulation

À faire monter

CIBLE PROPOSÉE

**Plus de signalements que
de clics**



Taux de clic
en simulation

À faire baisser

CIBLE PROPOSÉE

**En baisse à chaque
campagne**



Délai de signalement
après réception

À réduire

CIBLE PROPOSÉE

Moins de 30 minutes



Couverture MFA
des comptes

À compléter

CIBLE PROPOSÉE

100 % sous 30 jours

Repère : après une formation récente, 21 % des collaborateurs signalent un e-mail piégé, contre 5 % sans formation (Verizon DBIR 2025).



**Restitution : un tableau de bord trimestriel d'une page
présenté à la direction.**

Trois décisions pour aujourd'hui

1



**Activer le MFA pour tous,
direction comprise**

Sous 30 jours. Généralement inclus dans
nos abonnements actuels.

2



**Officialiser la double
validation des virements**

Toute demande de virement ou de
changement de RIB est confirmée par un
second canal.

3



**Lancer le programme de
sensibilisation**

1 h par personne et par an, simulations
trimestrielles, tableau de bord à la
direction.

Pilote proposé : le service informatique, avec un premier point d'étape à 90 jours.

À retenir



S'arrêter et vérifier

Expéditeur, lien, demande : trois secondes de doute évitent des semaines de crise.



Protéger les accès

MFA, filtrage des e-mails et double validation des virements.



Signaler vite

Une alerte précoce limite les dégâts : signaler sans crainte, toujours.

Dans le doute : je ne clique pas, je vérifie, je signale.

MERCI

Place à vos questions

Dans le doute : je ne clique pas, je vérifie, je signale.

Service informatique • Tafré Mefré

17Cyber.gouv.fr • cybermalveillance.gouv.fr



Sources



Cybermalveillance.gouv.fr / OpinionWay — Baromètre national de la maturité cyber des TPE-PME, 2e édition, octobre 2025. 588 entreprises de moins de 250 salariées, interrogées du 2 juin au 7 juillet 2025.



Cybermalveillance.gouv.fr — Rapport d'activité et état de la menace 2025, mars 2026 (504 810 demandes d'assistance, +73 % pour les entreprises et associations).



Verizon — Data Breach Investigations Report (DBIR) 2025 : facteur humain, vecteurs d'accès initial, effet de la formation sur les signalements.



Microsoft Research — « How effective is multifactor authentication at deterring cyberattacks? », 2023 : -99,2 % de risque de compromission avec MFA.



Textes de loi — Code des assurances, art. L12-10-1 (loi LOPMI du 24 janvier 2023) ; RGPD, art. 33 (notification à la CNIL sous 72 h).



Affaire Arup — Fraude par deepfake en visioconférence, Hong Kong, janvier 2024 (≈ 25 M\$), confirmée par l'entreprise en mai 2024.

Chiffres arrondis tels que publiés ; ils peuvent évoluer d'une édition à l'autre. Le scénario du faux RIB et les e-mails du quiz sont fictifs.